# OMNEX Mainnet v3 — Defect Register

Nov 7, 2026 · @Sultan of AI

## Scope and severity scale

26 defects across the OMNEX Mainnet v3.0.0 bundle (`p2p`, `mempool`, `sync`, `ledger`, `node`, `Cargo.toml`). The bundle does not build; no ticket below can be verified at runtime until the P0 set is closed. Every ticket is open as of the as-of date.

| Severity | Meaning | Count |
|---|---|---|
| P0 Blocker | Prevents `cargo build --workspace`, or a core subsystem is absent | 7 |
| P1 Critical | A claimed security property is not implemented; exploitable by a single malicious peer | 8 |
| P2 High | A running node would deadlock, fork, or stop within minutes | 7 |
| P3 Medium | Robustness, performance, or hygiene; fix before testnet | 4 |

Ticket IDs are `OMX-<n>`. Each row carries the file, the defect, the impact, and the fix.

## P0 — Blocker: does not build / missing core components

Nothing below P0 can be exercised until these seven are closed. OMX-001 is the largest: the consensus engine, the thing that makes this a blockchain, does not exist in the bundle.

| ID | File | Defect | Impact | Fix |
|---|---|---|---|---|
| OMX-001 | `node/src/main.rs`, `Cargo.toml` | `consensus`, `rpc`, `crypto`, `indexer` crates are listed or referenced but absent. `BftEngine`, `ConsensusEvent`, `start_rpc_server`, `load_or_init_keypair` are undefined. | No consensus, no RPC, no node. The BFT algorithm is still unchosen ("e.g., Tendermint/CometBFT/HotStuff"). | Choose the engine (CometBFT via ABCI, or a HotStuff crate). Add the four crates with real implementations or remove them from the workspace until they exist. |
| OMX-002 | `sync`, `node` | `crate::p2p::P2P`, `crate::ledger::Ledger`, `crate::mempool` used across crate boundaries. | Unresolved paths in every dependent crate. | Add `[dependencies] p2p = { path = "../p2p" }` etc. and import as `p2p::P2P`. |

| ID | File | Defect | Impact | Fix |
|---|---|---|---|---|
| OMX-003 | `p2p`, `mempool`, `node` | `ed25519-dalek 2.1` API mismatch: `Keypair`, `PublicKey`, `keypair.public`, `Keypair::clone()`, `Signature::from_bytes` returning `Result` are all 1.x. | p2p, mempool and node fail to compile. | Port to `SigningKey` / `VerifyingKey`; `Signature::from_bytes(&[u8;64])` is infallible in 2.x. |
| OMX-004 | `p2p/src/lib.rs` | `rustls 0.23` API mismatch: `rustls::Certificate`, `PrivateKey`, `ServerName` removed. `rcgen 0.13`: `Certificate::from_params`, `serialize_der` removed; `not_before` is `OffsetDateTime`. `quinn 0.11`: `finish()` is sync. | p2p fails to compile. | Use `rustls_pki_types::{CertificateDer, PrivateKeyDer}`; `rcgen::KeyPair` + `CertificateParams::new(..)?.self_signed(&key)`; drop `.await` on `finish()`. |
| OMX-005 | `mempool/src/lib.rs` `insert()` | `account_map` holds a live `&mut` into `by_account`; the eviction branch calls `by_account.get_mut()` while `account_map` is used afterward. | E0499, mempool fails to compile. | Run eviction before taking the `entry()` borrow, or re-fetch `account_map` after eviction. |
| OMX-006 | `sync/src/lib.rs` | `read_chunk_bounded`, `P2P::get_active_peers`, `Ledger::{start_atomic_batch, commit_atomic_batch, rollback_sync_batch, compute_state_root}`, `SyncRequest`, `info!`, `hex` all undefined. | sync fails to compile. | Implement the ledger batch and trie-root APIs; use `RecvStream::read_chunk(max, true)`; add `hex` and `tracing` deps. |
| OMX-007 | `node/src/main.rs`, `ledger/src/lib.rs` | `WireTx::canonical_tx()` and `Ledger::apply_state_transition()` undefined. | Block commit path does not compile. | Define canonical serialization on `WireTx`; implement state transition with balance and |

| ID | File | Defect | Impact | Fix |
|---|---|---|---|---|
| | | | | nonce updates in `CF_STATE`. |

## P1 — Critical: security properties claimed but absent

Each of these is named in a comment or docstring as implemented and is not. A single malicious peer can exploit OMX-010 through OMX-014 without any validator collusion.

| ID | File | Defect | Impact | Fix |
|---|---|---|---|---|
| OMX-008 | `p2p spawn_inbound_accept_loop` | Every inbound peer is registered as `mock_peer_id = [1u8; 32]`. The comment defers verification to "production". | No inbound peer authentication. All inbound sessions collide on one map key; any host can pose as a validator. | Mutual TLS with a custom `ServerCertVerifier` / `ClientCertVerifier`; derive `NodeId` from the peer's verified Ed25519 key, or run an authenticated handshake on the first bidi stream. |
| OMX-009 | `p2p create_authenticated_client_config` | "Pin expected NodeId in verification" comment, no code. Default WebPKI verifier is used; `ServerCertVerifier` import unused. | No pinning. Worse, self-signed server certs fail WebPKI, so `dial()` cannot complete a handshake. | Install a verifier that checks the presented cert's embedded public key equals `expected_node_id`; `dangerous().with_custom_certificate_verifier(..)`. |
| OMX-010 | `p2p generate_persistent_cert` | The `keypair` argument is ignored; a fresh random cert is minted on every call, including every `dial`. | No binding between TLS identity and Ed25519 `NodeId`. "Persistent" and "pinning" are both impossible as written. | Derive the TLS key from the node's Ed25519 key (rcgen supports Ed25519 `KeyPair::from_der`) or embed the Ed25519 public key in a cert extension and verify it. |
| OMX-011 | `sync MerkleRangeProof::verify` | `left_boundary_key`, `right_boundary_key` and | The "range" in the range proof is unverified: a peer can serve a valid | Verify the chunk's keys lie in `[left, right]`, that consecutive chunks' ranges are |

| ID | File | Defect | Impact | Fix |
|---|---|---|---|---|
| | | `ChunkEnvelope.key_range` are never checked. | leaf for any claimed range, omit ranges, or duplicate them, and still pass. | contiguous and non-overlapping, and that the proof covers the boundary keys. |
| OMX-012 | `sync` `MerkleRangeProof::verify` | Sorted-pair hashing with no leaf/internal domain separation. | Second-preimage exposure (same family as CVE-2012-2459): an internal node can be presented as a leaf. | Prefix leaves with `0x00` and internal nodes with `0x01`; fix sibling ordering by position, not by value. |
| OMX-013 | `sync` `warp_sync` loop | `chunk_index` monotonicity unchecked; `total_chunks` re-read from each untrusted envelope; loop ends on the peer's `index + 1 == total`. | Peer controls completeness. Reordered, missing or repeated chunks are accepted; an early exit yields a partial state that still gets committed. | Fix `total_chunks` from the first envelope, require `chunk_index == applied_chunks`, and refuse commit unless `applied_chunks == total_chunks`. |
| OMX-014 | `sync` `warp_sync` | Batch is committed to RocksDB, then the root is recomputed and a "rollback" attempted. | Commit-then-verify. An unverified state is durable on disk before any check; rollback semantics are undefined. | Compute the root from the staged batch (or a snapshot) and commit only on match. |
| OMX-015 | `sync` `warp_sync` | `bincode::deserialize` on peer bytes without a size limit; the 4 MB read cap does not bound the length prefixes inside. | Pre-allocation DoS: a 4 MB envelope can declare a multi-GB `Vec`. | `bincode::DefaultOptions::new().with_limit(MAX_BOUNDED_CHUNK_SIZE as u64)` on every deserialize of network data. |

## P2 — High: correctness bugs that would break a running node

If the P0 and P1 sets were closed and nothing else changed, a node would still lose all peers within 60 seconds (OMX-019), deadlock under load (OMX-016), and propose invalid blocks (OMX-018).

| ID | File | Defect | Impact | Fix |
|---|---|---|---|---|
| OMX-016 | `mempool` `insert` / `pop_batch` | Lock-order inversion: `insert` takes `by_account` then `by_fee`; `pop_batch` takes `by_fee` then `by_account`. | Deadlock under concurrent submission and block packaging. | One `RwLock<MempoolInner>` holding both indices, or a fixed acquisition order enforced in both paths. |
| OMX-017 | `mempool` `compute_canonical_hash` vs `ledger` `archive_with_segregated_witness` | Mempool hashes fields one by one; ledger hashes `blake3(serialized bytes)`. | The same transaction has two different IDs. RPC lookups by txid, witness retrieval and explorer indexing all break. | One canonical encoding (`WireTx::canonical_tx()` from OMX-007) hashed identically everywhere. |
| OMX-018 | `mempool` `pop_batch` | Takes globally highest-fee entries with no per-account nonce ordering. | A block can carry nonce 7 without nonce 6; the proposal fails validation or forks state. | Package per-account in nonce order; only the lowest pending nonce of each account is eligible at each step (standard "ready set" packaging). |
| OMX-019 | `p2p` `spawn_heartbeat_pruning_loop` | `last_seen` is set once at insert and never updated; prune threshold is 60 s. | Every peer is dropped one minute after connecting regardless of activity. The network partitions itself. | Update `last_seen` on every received frame or on QUIC keep-alive ACK; prune on `Connection::close_reason()` instead. |
| OMX-020 | `sync` `warp_sync` | "Multi-peer round robin" comment; `peer_idx = 0` never changes. | Single-peer dependency; one bad peer stalls sync. | Rotate on failure; cross-check the root with a second peer before commit. |
| OMX-021 | `node/src/main.rs` commit loop | `ledger.apply_state_transition(..)?` inside the event loop. | Any failure applying a committed transaction returns from `main` and kills the validator. | Validate before voting (in `verify_proposal`); on apply failure after QC, halt consensus with a diagnostic rather than exit. |

| ID | File | Defect | Impact | Fix |
|---|---|---|---|---|
| OMX-022 | `mempool` eviction | Evicting the min-fee entry can remove nonce k while nonce k+1 from the same sender stays. | Permanent nonce gap; the sender's later transactions never become eligible. | Evict the highest nonce of the lowest-fee account, or evict the whole tail from the gap upward. |

## P3 — Medium: robustness, performance, hygiene

None of these blocks a testnet on its own; all four should be closed before one.

| ID | File | Defect | Impact | Fix |
|---|---|---|---|---|
| OMX-023 | `ledger`, `node` | `async fn` wrappers around synchronous RocksDB writes; `cf_handle(..).unwrap()`. | Blocks the tokio runtime on every commit; a missing CF panics. | `tokio::task::spawn_blocking` for DB I/O; return `Result` on missing CF. |
| OMX-024 | `mempool` | `fee_rate` is "per byte" but no size is computed; RBF `fee_rate * 110` is unchecked `u64`; no balance check at admission. | Fee market is nominal; overflow on extreme values; mempool accepts transactions the sender cannot fund. | Compute size from canonical encoding; `checked_mul`; pass account balance alongside nonce at insert. |
| OMX-025 | `mempool` | "Stable Rust replacement for nightly `pop_first()`" workaround. | Dead workaround; `BTreeSet::pop_first/pop_last` stable since Rust 1.66 (Dec 2022). Signals the code was not written against a current toolchain. | Use `pop_first()` / `pop_last()`; set `rust-version` in `Cargo.toml`. |
| OMX-026 | Repository | No tests, benchmarks, fuzz targets, CI config, or `rpc` / `indexer` sources despite "production" labelling. | No evidence any path has been executed. | Minimum bar: `cargo test` passing per crate, a fuzz target on `MerkleRangeProof::verify` and `ChunkEnvelope` decoding, a multi-node integration test. |

## Summary and recommended order of work

Close in the order below; each phase gates the next because nothing can be tested until it builds, and nothing can be trusted on a network until peers are authenticated.

1. **Build (OMX-001 to OMX-007).** Pin the dependency APIs and choose the consensus engine before touching anything else; roughly 60% of the remaining tickets are only testable after this.
2. **Peer identity (OMX-008 to OMX-010).** One fix: derive the TLS identity from the Ed25519 key and verify it on both sides. This closes all three.
3. **Sync integrity (OMX-011 to OMX-015, OMX-020).** Rewrite `MerkleRangeProof` with domain separation and range checks, verify before commit, bound deserialization. Fuzz it.
4. **Mempool (OMX-005, OMX-016 to OMX-018, OMX-022, OMX-024).** Single-lock redesign with per-account ready-set packaging. The most salvageable crate; a clean rewrite is about 300 lines.
5. **Node lifecycle (OMX-019, OMX-021, OMX-023).** Liveness tracking, no `?` out of `main`, blocking I/O off the runtime.
6. **Evidence (OMX-025, OMX-026).** Tests and CI before anyone calls it a testnet.

| Component | P0 | P1 | P2 | P3 | Total |
|---|---|---|---|---|---|
| p2p | 2 | 3 | 1 | 0 | 6 |
| sync | 1 | 5 | 1 | 0 | 7 |
| mempool | 2 | 0 | 4 | 2 | 8 |
| ledger | 1 | 0 | 0 | 1 | 2 |
| node / workspace | 1 | 0 | 1 | 1 | 3 |
| **Total** | **7** | **8** | **7** | **4** | **26** |

Component counts assign each ticket to its primary file (OMX-003 and OMX-017 touch several).